Executive Briefing

CYBERSECURITY CONSULTANCY PROJECT

CYBERSECURITY RISK ASSESSMENT AND RANSOMWARE RESILIENCE STRATEGY FOR A MULTI-SITE HEALTHCARE PROVIDER

Programme: Certified Cybersecurity Consultant (CSCC), Cohort 11
Course: CCC104 – Capstone Project
Academic Period: 2026 | Level 1 | Semester 2
Project ID: CAP-20261022-E1E80DDE52
Assessment Sites: Facility A (FAC-A) and Facility B (FAC-B)
Project Type: Simulated Cybersecurity Consultancy Engagement
Date: November 2026

PROJECT OVERVIEW AND KEY FINDINGS

1. Executive Overview

This consultancy project presents a cybersecurity risk assessment and ransomware resilience strategy for a simulated Nigerian private healthcare provider operating across two locations: Facility A (FAC-A), the main facility, and Facility B (FAC-B), the satellite facility.

The organisation is assumed to employ approximately 80 personnel and depend on interconnected digital services, including electronic health records (EHR), patient registration, appointment management, billing, email, shared storage, administrative reporting and network infrastructure.

The purpose of the engagement is to assess the organisation's assumed cybersecurity posture, identify weaknesses that could expose critical healthcare services to ransomware and other cyber threats, and develop a practical improvement strategy.

The assessment follows the National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) 2.0, covering its six functions: Govern, Identify, Protect, Detect, Respond and Recover.

The engagement is simulation-based. It does not represent an authorised penetration test or a live assessment of an operating healthcare organisation. No real patient information or production systems were used. Practical validation activities were conducted in an isolated laboratory environment using synthetic data.

2. Assessment Approach

The consultancy applied the following activities:

1. Organisational and IT environment review.
2. Asset identification and classification.
3. Current-state cybersecurity assessment.
4. Identification and evaluation of 15 cybersecurity risks.
5. Development of a proposed security improvement architecture.
6. Laboratory validation of selected security controls.
7. Development of a ransomware incident response and recovery playbook.
8. Conduct of a discussion-based ransomware tabletop exercise.
9. Preparation of a costed 90-day security improvement roadmap.
10. Development of a management cybersecurity KPI dashboard.

3. Key Findings

The assessment identified cybersecurity exposure areas requiring management attention.

Security area	Key concern	Recommended direction
Identity and access management	Excessive or poorly controlled access could expose sensitive systems	Role-based access, MFA and privileged access controls
Endpoint security	Compromised workstations could provide an entry point for ransomware	Endpoint protection, patching and hardening
Network security	Unrestricted communication between systems could support lateral movement	Network segmentation and default-deny access
Backup and recovery	Inadequate backup isolation or recovery testing could increase downtime	Isolated backups and regular restoration testing
Monitoring and detection	Incomplete security logging could delay incident identification	Centralised logging, alerting and monitoring
Incident response	Unclear responsibilities could delay containment and recovery	Documented incident response procedures and exercises
Governance	Weak oversight could reduce accountability for security improvements	Management ownership, policies and performance monitoring

The project developed a 15-risk assessment register, a proposed seven-zone network architecture and a set of prioritised security improvements. The actual risk scores and residual ratings must be taken from the approved risk register rather than inferred from this summary.

4. Practical Validation

Selected controls were demonstrated in an isolated Windows laboratory using synthetic data.

The reported practical outcomes include:

- Nine out of nine expected role-based access control decisions passed.
- Windows process command-line auditing was demonstrated.
- Failed logon events were reviewed using Windows Security Event ID 4625.
- File access auditing was reviewed using Event ID 4663.
- File system audit policy and SACL configuration were checked.
- Three synthetic files were restored and their SHA-256 hashes compared.

These results demonstrate selected control behaviours under laboratory conditions. They do not establish that equivalent controls are deployed or effective across a real healthcare organisation.

PROPOSED IMPROVEMENTS AND MANAGEMENT DECISIONS

5. Proposed Security Improvement Strategy

The proposed improvement architecture is organised around seven security zones:

1. Clinical and user workstations.
2. Clinical applications.
3. Shared storage and file services.
4. Infrastructure and Active Directory management.
5. Isolated backup storage.
6. Perimeter gateway and secure remote access.
7. Guest wireless network.

The design recommends controlled communication between network zones, restricted administrative access, multi-factor authentication, endpoint protection, centralised monitoring, secure backup arrangements and documented recovery procedures.

The architecture and IP subnet allocations are proposed designs. They should not be interpreted as an existing deployed network.

6. Ransomware Preparedness and Response

A ransomware incident response and recovery playbook was developed for the two-facility environment.

The playbook addresses:

- Incident identification and escalation.
- Isolation of affected endpoints and systems.
- Protection of unaffected services.
- Evidence preservation.
- Communication with management and relevant stakeholders.
- Recovery from verified backups.
- Post-incident review and corrective action.

A discussion-based tabletop exercise, Operation DryRUN, was conducted on 28 October 2026. The scenario involved an assumed remote access compromise followed by EHR encryption affecting both facilities.

The exercise was designed to evaluate coordination and decision-making. It was not a live ransomware attack or technical penetration test.

7. Proposed 90-Day Investment

The improvement roadmap provides a phased implementation plan covering three 30-day periods.

Budget item	Planning estimate
Cash implementation subtotal	₦23,300,000
15% contingency	₦3,495,000
Total cash requirement	₦26,795,000
Approximate USD equivalent at ₦1,350/$	$19,848

The figures are planning estimates as at 4 November 2026, not verified supplier quotations. Annual subscriptions, software/tool licensing and internal labour estimates should be reconciled against the detailed costing workbook before management approval to avoid double counting.

8. Management Recommendations

Management is advised to:

1. Approve the prioritised 90-day cybersecurity improvement roadmap.
2. Assign accountable owners to the identified risks and corrective actions.
3. Prioritise identity security, endpoint protection, network segmentation and backup isolation.
4. Fund centralised security monitoring and incident response capability.
5. Establish regular backup restoration tests and ransomware tabletop exercises.
6. Introduce monthly cybersecurity KPI reporting.
7. Review the security programme quarterly and update the risk register as the environment changes.

9. Decisions Required

Management approval is requested for:

- The proposed security architecture as the target design.
- The phased implementation roadmap.
- The proposed cash planning budget, subject to procurement validation.
- Assignment of control owners and implementation responsibilities.
- Regular monitoring and reporting of cybersecurity performance.

10. Conclusion

The consultancy provides a structured approach for improving ransomware resilience in a simulated multi-site healthcare environment. It combines risk assessment, security architecture, practical laboratory validation, incident response planning and management oversight.

The proposed controls require formal management approval, implementation, procurement and subsequent operational testing. This report is not a certification of regulatory compliance or proof of the cybersecurity effectiveness of a live healthcare organisation.

Prepared by:
Cohort 11 – Cybersecurity Consultancy Project Team
Certified Cybersecurity Consultant Programme